

Session summary — 28 July 2026

Demo-readiness review, client-call backlog, and the bugs found along the way.

1. Bugs found and fixed

Most of these were found by probing rather than by the test suite, which is the main argument for the per-role QA runs still outstanding.

Technician job completions were silently orphaned

The 24 July role-scoping sweep put `jobs` writes in `TENANT_WRITE` (admin + estimator) while `job_completions` stayed `TENANT_FIELD` (+ technician). Correct tiering, but `JobCompletionService.createCompletion` then did:

```
INSERT job_completions      technician: allowed
UPDATE jobs SET completion_id technician: refused by RLS
```

An RLS refusal matches zero rows and **raises no error**, and the call site never checked rows-affected. A technician's completion was created and orphaned with nothing surfaced — the audit's "Pattern A: silent success", reintroduced. It shipped after the 20–21 July QA pass, so no UI run had covered it.

Fixed with a `SECURITY DEFINER` trigger rather than widening the `jobs` policy, so technicians don't gain edit rights on contract amounts just to link a completion. Includes a backfill.

16 database functions were dead

A `search_path` hardening pass set `SET search_path TO ''` without schema-qualifying the table references inside the function bodies. Every one threw `relation "... " does not exist` on every call.

Surfaced by a user-reported "Failed to fetch notifications" toast; `GET /api/notifications` was returning **500** for signed-in users. Scanning for the same shape found fifteen more:

FUNCTION GROUP	WHAT WAS BROKEN
<code>log_audit_event</code> , <code>log_platform_access</code>	Audit logging silently dead
<code>check_tenant_limits</code> , <code>increment_tenant_usage</code> , <code>reset_tenant_usage</code>	Plan limits and usage metering
<code>allow_first_org_creation</code> , <code>can_create_organization</code>	RLS helpers used by onboarding
<code>get_feedback_survey_by_token</code> , <code>validate_feedback_token</code> , <code>submit_feedback</code>	The whole customer feedback portal
<code>check_ai_enabled</code> , <code>check_ai_feature_enabled</code> , <code>log_ai_usage</code>	AI feature gating

`create_notification_for_role` , `cleanup_expired_notifications`

Notifications

Fixed by pinning `search_path` to `public, pg_temp` — keeps the hardening's goal (the path is still fixed at definition time) without rewriting sixteen bodies.

The customer feedback portal had never worked

`get_feedback_survey_by_token` selects `o.logo_url` , which does not exist on `organizations` (it is `email_logo_url`). Two faults masked each other: the `search_path` damage made it fail with `undefined_table` first, and the function catches exactly that and returns a tidy "Feedback system not configured". Repairing `search_path` moved the failure to `undefined_column` , which isn't caught — and the RLS suite caught it.

The Radix bump silently broke 49 components

Radix stopped setting `displayName` on its primitives; 49 components across 15 files copied theirs from it, so all became `undefined` . Named explicitly instead, which removes the dependency on a library internal.

Two Jobs lists that disagreed

`/jobs` and `/crm/jobs` were both live full implementations with different filters, pagination and status configs. `/jobs` now redirects to the canonical CRM list. Collapsing it exposed that the **documents hub had been stranded** on the legacy page — document upload, OPP generation and waste labels were all unreachable from normal navigation. Now rendered on the CRM job's Documents tab.

Demo tenant was emailing domains we don't own

Seeded contacts used plausible external domains (`frsd14.k12.co.us` , `cherrycreekpq.com` , `example.com`). The app sends real mail — a verification test actually dispatched to a domain we don't control. All demo addresses are now plus-addresses on a domain we own. **My error.**

CI build broken by a Windows-regenerated lock file

Deleting `package-lock.json` and regenerating on Windows captured only win32 binaries — 2 platform entries where there had been 25 — so Linux CI couldn't resolve `@rollup/rollup-linux-x64-gnu` . **My error,** and it reached main because I ran type-check/lint/tests but not `npm run build` .

2. Features built

FEATURE	NOTES
Waste container labels	Avery 5162 sheet (14 per page, 4" × 1½"), generated from job data, stored as a job document. Optional OSHA warning block, off by default.
Chain-of-custody form	The sheet that travels with lab samples. Required a new <code>lab_report_samples</code> table — <code>lab_reports</code> held one free-text description where a real submission is a numbered list.

Summit Abatement demo tenant	Full survey → estimate → proposal → job → invoice story. 7-person team, 5 companies, 10 contacts, 9 opportunities across every stage, 9 properties, 8 surveys, 6 estimates, 5 proposals (2 signed), 7 jobs, 5 invoices with a real AR mix, 2 labs, 9 lab reports, 22 R2 photos. Idempotent seed.
Survey changes	"Utility shutoffs located" → "Is power/water available?" (field renamed, not just relabelled — different question). Exterior photos 4 → 1. Site access contact added.
Generate Work Order	Button on the job; the API had always accepted a <code>job_id</code> .
Financials hidden from technicians	New <code>ROLES.FINANCIAL_VIEW</code> . The Overview card was also printing Revenue, so that's gated too.

3. Verification tooling added

SCRIPT	PURPOSE
<code>scripts/verify-role-writes.mjs</code>	Signs in as all five roles with the public anon key — the browser's own path — and runs 55 write and 70 read probes against the expected tier matrix. Currently clean.
<code>scripts/probe-technician-completion.mjs</code>	Isolates the completion path and verifies via service role whether the link actually landed.
<code>scripts/check-live-redirect.mjs</code>	Mints an SSR auth cookie to check deployed routes as a signed-in user.

4. Dependencies

Merged 7 of 8 dependabot PRs (react, radix, aws, supabase, testing, setup-node).

Excluded the tooling group. It bumps TypeScript 5→7 and ESLint 9→10 while leaving `@typescript-eslint` at 8.65, whose peer range is `<6.1.0` — the tree doesn't resolve and that PR's own CI fails every check. Two May PRs were stale rather than additive and would have *downgraded* `@vitest/coverage-v8` and `@supabase/ssr`; conflicts resolved in favour of what main already had.

5. Migrations pushed (5)

- `20260728000001` — job completion → job link trigger
- `20260728000002` — `waste_label` document category
- `20260728000003` — 16 broken `search_path` functions
- `20260728000004` — `lab_report_samples` + chain-of-custody fields
- `20260728000005` — feedback survey column fix

6. Current state

Type-check clean · lint clean on tracked source · **6,035 tests passing** · production build succeeds · tree clean, all pushed to main.

The only failing CI job is **Security Audit**, on 17 pre-existing npm advisories (10 production, all the `exceljs` → `archiver` → `minimatch` chain). Failing since 27 July, unrelated to this work.

What remains

Full detail in `client-feedback-2026-07-28.md`.

P1 — broke live in front of the client

- **Estimate: preview what the customer sees** — no customer-facing view exists
- ~~Send email errors~~ — done, see above

P2 — small, visible (the sweep that makes August testing go well)

Contact Type field · address on the pipeline card · property list contacts/jobs clickable · add contact from property · archive contact · archive survey · "no visit" flag · phone on estimate · lab report file naming · lab reports permanently on the property

P3 — core workflow

Estimate versions with an active version · change order button · Materials Used tab (materials + time) · survey image rename/metadata/watermark

P4 — field workflow (highest risk)

Quick Create Appointment · time tracking with supervisor approval

Gina raised Bob's field usage twice and he agreed he often has seconds between appointments. Expect two or three passes *with Bob*, so worth starting earlier than its priority implies.

P5 — integrations (all blocked)

QuickBooks · RingCentral · Gmail · form-fill auto-messaging · AI pricing extraction

Carried over

Per-hazard waste labels · per-role QA runs

Decisions needed

1. **Team logins are on** `@summitabatement.com`, a domain we don't own. They're sign-in identities rather than correspondence, but job-assignment notifications would attempt delivery and bounce. Left alone

because the credentials are already out. Move them, or accept the bounces?

2. **Financial hiding is UI-level only.** A technician can still read `contract_amount` / `actual_revenue` via the API, since they need the job row for everything else. Real enforcement needs column-level restriction or a technician-facing view. Sufficient as-is?

Needed from the client

Ordered by how much they unblock:

1. Google Drive access to past estimates + OTS supplier invoices → AI pricing
2. RingCentral credentials → calls, SMS, click-to-call (lets us drop Twilio)
3. QuickBooks credentials
4. The new-lead messaging flow — what the text and email should say
5. Example waste labels for lead, mould, friable vs non-friable asbestos
6. Confirmation the regulatory-trigger list is complete

Process note

Two things reached main unverified today and had to be fixed after the fact: a type error from the survey rename, and the lock file. Both were caught by CI rather than by me. The gap was running type-check/lint/tests but not `npm run build` before pushing — worth making that the standing pre-push check.